

Incident Response Plan & Tabletop Exercise — Meridian Electronics

A self-directed GRC project building a full Incident Response Plan (IRP) for a mid-size manufacturer and stress-testing it through a tabletop simulation of a ransomware incident — the core compliance requirement behind ISO 27035 and SOC 2 CC7.x.

Project Summary

This project builds an Incident Response Plan for **Meridian Electronics**, a fictional mid-size electronics manufacturer (~200 employees) with a hybrid IT/OT environment — corporate systems (ERP, email, file servers) alongside a separate operational technology environment (production line control systems). Rather than treating the IR plan as a static document, the project tests it against a realistic tabletop scenario: a phishing email leads to credential compromise, which an attacker uses to deploy ransomware against corporate systems overnight on a weekend. The project follows the full ISO 27035 incident management lifecycle:

- 1. **IR Team design** — building a realistic 19-role response structure across Core, Extended, and Support/External tiers, including associate/junior staff who execute hands-on response actions
- 2. **Procedure design** — writing Detection, Containment, Eradication, and Recovery procedures specific to a hybrid IT/OT environment, with explicit phase-gating (no remediation during detection, no recovery before eradication is confirmed)
- 3. **Tabletop simulation** — running the scenario against a realistic, mixed-quality response (not a perfect one), including a 24/7/365 hybrid MSSP monitoring model tested specifically by setting the incident overnight on a weekend
- 4. **Incident documentation** — producing a filled Incident Report mapped to ISO 27035, SOC 2 CC7.x, and ISO 27001 Annex A control references, plus a fully timestamped Incident Timeline
- 5. **Lessons Learned analysis** — identifying three real findings from the simulation and converting each into a specific, traceable policy update to the IR Plan itself

Deliverables

File	Description
Meridian_Incident_Response_Plan.docx / .pdf	The reusable IR Plan: Purpose, full 19-role team structure, Detection/Containment/Eradication/Recovery procedures, Lessons Learned process, Severity-Based Escalation Matrix, and recurring testing requirement
Meridian_Incident_Simulation_Report.docx / .pdf	The one-time simulation record: filled Incident Report with compliance framework mapping, full timestamped timeline, and Lessons Learned findings

What I Did

- Designed a 19-role incident response team spanning Core decision-makers, Extended business-function leads, Support/External partners, and the associate/junior staff who actually execute response steps — rather than a flat, oversimplified team structure
- Distinguished IT-side containment from OT/production-side containment, reflecting that “isolate the system” means something materially different (and riskier) on a manufacturing floor than on a corporate network
- Wrote phase-gated procedures across Detection, Containment, Eradication, and Recovery, each with an explicit goal and an explicit rule about what *not* to do yet (e.g., never powering off a compromised machine before forensic evidence is preserved)
- Built a 24/7/365 hybrid MSSP monitoring model and specifically tested it by setting the simulated incident overnight on a weekend, rather than during convenient business hours
- Produced a full incident timeline with real timestamps, calculating Time to Detect, Time to Contain, and Time to Recover — the same metrics real SOC 2 audits and board security reports reference
- Mapped the incident response directly to ISO 27035 lifecycle stages, SOC 2 CC7.2/7.3/7.4, and ISO 27001 Annex A controls, so the documentation is usable as actual audit evidence
- Identified three genuine findings from the simulation and converted each into a four-part structured finding (Root Cause, Why It Matters, Policy Update, and which IR Plan section it updates) rather than vague “lessons learned” prose
- Updated the IR Plan itself based on the findings — adding a Severity-Based Escalation Matrix and a formal recurring tabletop testing requirement — so the simulation produced a better plan, not just a report about one

What I Learned

- **A plan is only as good as its untested assumptions.** The original IR plan implicitly assumed business-hours detection. That assumption was invisible until the simulation specifically placed the incident overnight — a reminder that tabletop exercises exist to find the gaps a plan doesn’t know it has, not to rehearse the parts that already work.
- **Speed in one phase doesn’t guarantee speed everywhere.** Adding 24/7 MSSP monitoring dropped detection time by over 95%, but the Cyber Insurance Carrier notification still quietly waited for business hours, because no one had explicitly extended the “always-on” assumption to that specific step. Fast technical response and fast business-process response are two different things that both need to be designed for.
- **Roles need a clear chain of command, not just a list of names.** Having a Technical Lead report findings to an Incident Commander — rather than making independent containment calls — prevents two common real failure modes: unauthorized business-impacting decisions, and indecision when someone is waiting for permission that was never going to come.
- **OT and IT containment are not interchangeable.** Writing “isolate the affected system” once and applying it everywhere ignores that a factory floor has physical safety and equipment-damage considerations a corporate network doesn’t. This requires a

genuinely different role (Controls Engineer) and a genuinely different procedure, not just a copy-pasted IT step.

- **A finding is only useful if it's traceable to a specific fix.** Writing “communication could be better” teaches nothing. Writing “add Cyber Insurance Carrier notification to the Incident Commander’s on-call checklist, updating IR Plan Section 2” is something a real organization could implement and verify next quarter.

Real-World Application

Incident response planning and testing is a named, explicit requirement in major compliance frameworks, not an optional best practice:

- **SOC 2 CC7.x compliance** — auditors specifically look for evidence of incident detection, response, and recovery procedures, and increasingly expect evidence that those procedures have actually been tested, not just written
- **Cyber insurance underwriting** — insurers increasingly require evidence of a tested IR plan, a pre-contracted forensics partner, and defined notification procedures before issuing or renewing coverage, exactly the elements built into this plan
- **Manufacturing-specific risk** — manufacturing is one of the most frequently targeted industries for ransomware specifically because production downtime creates outsized pressure to pay; an IT/OT-aware IR plan reflects the real operational stakes this industry faces
- **Regulatory breach notification timing** — the Severity-Based Escalation Matrix added after this exercise directly addresses a common real-world compliance failure: notification clocks that start at discovery, not at whenever Legal happens to wake up and find out

Conclusion

This project demonstrates the fourth core pillar of GRC analyst work, completing a portfolio that now spans compliance frameworks (NIST 800-53), internal risk management (the BudgetWise risk register), third-party risk (the Slack vendor assessment), and incident response (this project). Of the four, this one is the most explicitly cyclical: a tabletop exercise isn’t a one-time deliverable, it’s a mechanism for continuously finding the gap between what a plan assumes and what is actually true about an organization’s readiness. The most valuable output of this project wasn’t the original IR plan — it was the updated one, written only after the simulation revealed exactly where the first version would have failed. That distinction, between writing a plan and proving a plan, reflects the difference between compliance-on-paper and operational readiness that real GRC work is ultimately responsible for closing.

This is a self-directed portfolio project using a fictional organization and simulated incident. It does not reflect any real company’s incident history or response capabilities.

Incident Response Plan

Meridian Electronics

Aligned to ISO 27035 and SOC 2 CC7.x | Prepared by Kevin Liao

1. Purpose

This Incident Response Plan (IRP) establishes Meridian Electronics' approach to detecting, containing, eradicating, and recovering from information security incidents, with specific attention to the company's hybrid IT/OT (Operational Technology) environment. The plan is aligned with ISO 27035 (Information Security Incident Management) and SOC 2 Trust Services Criteria CC7.x (System Operations), and is intended to be actionable during an active incident, not solely a compliance artifact.

This plan covers the full incident lifecycle and is supplemented by a Severity-Based Escalation Matrix (Section 8) and a recurring tabletop testing requirement (Section 9), both added following the most recent simulation exercise.

2. Incident Response Team & Roles

Meridian maintains a three-tier Incident Response Team. Core roles hold decision-making authority during an active incident; Extended roles manage legal, communications, and business-continuity functions; Support/External roles provide specialized capacity the internal team does not maintain full-time. Each lead role is supported by associate/junior staff who execute hands-on response actions.

2.1 Core Decision-Making Team

Role	Responsibility
Incident Commander	Single point of authority during an active incident; activates the IR Team, makes containment/business decisions, and is the only role authorized to declare an incident resolved.
Technical Lead (IT/Security)	Leads detection investigation, containment, eradication, and recovery on corporate IT systems (email, ERP, file servers, endpoints).
OT/Production Lead	Manages containment decisions on the manufacturing floor, balancing security action against physical safety and equipment integrity.

2.2 Extended Response Team

Role	Responsibility
Legal/Compliance Lead	Assesses regulatory notification obligations, preserves evidence/chain of custody, manages law enforcement contact.
Communications Lead	Manages internal, customer/partner, and media messaging.
HR Lead	Manages internal workforce communications and

	personnel actions if an insider element is involved.
Finance Lead	Assesses financial exposure and liaises with the cyber insurance carrier on claims handling.
Customer/Supply Chain Liaison	Manages communication with key customers/suppliers regarding production or delivery impact.

2.3 Support & External

Role	Responsibility
Executive Sponsor (CEO/COO)	Briefed regularly by the Incident Commander; makes final high-stakes calls (e.g., ransom payment, disclosure timing).
External IR Firm / Forensics Partner	Pre-contracted third-party specialists engaged for deep forensic investigation.
Cyber Insurance Carrier Contact	Notified per policy requirements; may mandate use of approved IR/legal vendors.
MSSP After-Hours SOC Analyst	Monitors SIEM/EDR alerts continuously outside business hours; escalates confirmed high-severity alerts directly to the on-call Technical Lead.

2.4 Associate & Junior Staff

Role	Reports To	Responsibility
Security Analyst (SOC)	Technical Lead	Monitors alerts, performs initial triage, executes hands-on containment.
Systems Administrator	Technical Lead	Executes endpoint/server isolation, rebuilds, and backup restoration.
IT Help Desk Technician	Technical Lead	Fields employee reports of suspicious activity (often the first point of detection).
Production Floor Supervisor	OT/Production Lead	Executes physical shutdown/isolation procedures on the production line.
Controls Engineer	OT/Production Lead	Assesses industrial control system impact; manages safe reconnection.
Compliance Associate	Legal/Compliance Lead	Tracks notification deadlines, drafts regulatory language, maintains documentation log.
Internal Communications Associate	Communications Lead	Drafts and distributes employee-facing updates.
Account Manager (Key Accounts)	Customer/Supply Chain Liaison	Handles direct communication with major customers regarding delays.

3. Detection

Goal: confirm a real incident is occurring and classify its severity. No remediation action is taken during this phase.

1. Reports of suspicious activity (from an employee, via IT Help Desk) or automated alerts (from the MSSP, covering nights/weekends/holidays) are the two entry points into detection.
2. Help Desk or MSSP SOC Analyst escalates confirmed ransomware indicators (file extension changes, ransom notes, mass file modification alerts) immediately to the on-call Technical Lead, regardless of time of day.
3. Technical Lead confirms the indicator is genuine and declares a formal security incident, notifying the on-call Incident Commander.
4. Incident Commander activates the IR Team. Core roles are activated immediately regardless of hour; Extended Team activation timing follows the Severity-Based Escalation Matrix (Section 8).
5. Incident Commander opens the formal incident log, beginning the Incident Timeline record.

4. Containment

Goal: stop the incident from spreading further. Eradication and recovery actions are not taken during this phase.

6. Security Analyst (or MSSP, with on-call Technical Lead authorization) isolates affected endpoints from the network. Network-level isolation is used rather than power-off, to preserve forensic evidence (volatile memory, active connections).
7. Systems Administrator disables compromised account(s) and forces password resets; any additional accounts showing suspicious activity are disabled as discovered.
8. Technical Lead assesses lateral spread risk and recommends broader network segmentation to the Incident Commander as needed.
9. OT/Production Lead and Controls Engineer assess production system impact. If any risk is identified, containment uses network isolation only — never abrupt power loss — to avoid equipment damage or safety hazards.
10. Incident Commander notifies the Cyber Insurance Carrier directly and engages the pre-contracted External IR Firm, without waiting for business hours (see Section 8).
11. Legal/Compliance Lead begins evidence preservation and determines whether law enforcement notification (e.g., FBI IC3) is warranted.

5. Eradication

Goal: confirm the threat is fully removed from the environment. Recovery does not begin until eradication is formally confirmed.

12. External IR Firm (with Technical Lead) identifies the threat variant and confirms full scope of affected systems through forensic analysis.
13. Systems Administrator removes malware/persistence mechanisms from confirmed-affected systems, or rebuilds from a known-clean image where removal cannot be fully verified.
14. Security Analyst confirms no remaining indicators of compromise exist before sign-off.
15. Technical Lead formally confirms eradication is complete and reports to the Incident Commander.

6. Recovery

Goal: safely restore normal operations. The incident is not closed until an elevated monitoring period confirms no recurrence.

16. Systems Administrator restores affected systems from the most recent backup verified to predate the initial compromise.
17. Controls Engineer safely reconnects and tests production control systems before resuming full manufacturing operations.
18. Security Analyst applies enhanced monitoring to previously affected systems for an elevated observation period.
19. Communications Lead and Customer/Supply Chain Liaison issue resolution updates internally and to affected customers/partners.
20. Incident Commander formally closes the incident only once Technical Lead, OT/Production Lead, and Legal/Compliance Lead each confirm their area is resolved.

7. Lessons Learned Process

Following every declared incident (and every tabletop exercise), the Incident Commander convenes a Lessons Learned review within 5 business days. Findings are documented using the four-part structure: Root Cause, Why It Matters, Recommended Policy Update, and the specific IR Plan section the update applies to. Findings and their remediation status are tracked until closed, not filed and forgotten.

8. Severity-Based Escalation Matrix

Added following the most recent tabletop simulation, which identified ambiguity around when after-hours incidents warrant waking the Extended Team.

Severity	Criteria	Overnight/Weekend Action
Critical	Confirmed or suspected customer/employee data exposure, OT/production system compromise, or ransom demand received	Wake Core AND Extended Team immediately, including Legal/Compliance and the Cyber Insurance Carrier contact
High	Confirmed malware/ransomware activity, contained to internal systems, no confirmed data exposure	Wake Core Team immediately; brief Extended Team at start of business hours unless containment fails
Medium/Low	Suspicious activity under investigation, not yet confirmed as an active incident	On-call Technical Lead investigates; escalate to Incident Commander only if confirmed

9. Recurring Testing Requirement

Meridian will conduct a tabletop incident response exercise at minimum semi-annually, rotating scenario types (phishing/ransomware, credential leak, insider threat, OT-specific compromise) and varying time-of-day assumptions. This requirement exists because the most significant gap found in the most recent exercise — the absence of any 24/7 coverage assumption — was an untested assumption in the prior version of this plan, not a known risk. Findings from each exercise are tracked and remediated prior to the next scheduled exercise.

Incident Simulation Report

Tabletop Exercise: Ransomware via Phishing-Initiated Credential Compromise

Meridian Electronics | Prepared by Kevin Liao

1. Incident Report

Incident Identification

Incident ID: MER-2026-0614

Date/Time Detected: Saturday, 1:52 AM (overnight, via 24/7/365 MSSP automated detection)

Date/Time Resolved: Monday, 4:00 PM (2 days, 14 hours after detection)

Incident Type: Ransomware, via phishing-initiated credential compromise

Severity: High — production systems precautionarily isolated; no confirmed OT compromise or customer data exposure

Incident Commander: [Name], IT Director

Summary of Incident

An employee's mailbox auto-processed a phishing email at 1:47 AM Saturday, executing a malicious payload that harvested cached credentials. The attacker used the compromised credentials to deploy ransomware, encrypting files on a shared file server and 11 endpoints. Meridian's 24/7/365 MSSP monitoring detected anomalous mass file-modification activity within 5 minutes and escalated to the on-call Technical Lead, enabling containment within 52 minutes of detection. No customer data exposure or production system compromise was confirmed. The incident was fully resolved within approximately 2.5 days.

Scope & Impact

Systems Affected: 1 shared file server, 11 employee endpoints (Accounts Payable / Finance department)

Data Affected: Internal financial/accounting files; no confirmed customer PII or payment card data involved

Production Impact: Precautionary network isolation of production subnet; no confirmed compromise; zero missed shipments

Financial Impact: External IR firm engagement cost; no ransom paid; no confirmed regulatory penalty

Response Actions Taken

MSSP-led detection and initial isolation; on-call Technical Lead and Systems Administrator executed account containment and segmentation; External IR Firm engaged for forensic scope confirmation; affected endpoints rebuilt from clean images; file server restored from a pre-compromise backup; Legal/Compliance Lead preserved evidence and filed an FBI IC3 report; Communications and Customer/Supply Chain Liaison managed internal and customer messaging.

Compliance Framework Mapping

ISO 27035: 5.2 Plan & Prepare | 5.3 Detection & Reporting | 5.4 Assessment & Decision | 5.5 Responses — full lifecycle followed from preparation through lessons learned

SOC 2: CC7.2 Detection of security events | CC7.3 Evaluation & response to incidents | CC7.4 Recovery from identified incidents

ISO 27001 Annex A: A.5.24 IR planning | A.5.26 Response to incidents | A.8.16 Monitoring activities

2. Incident Timeline

Metrics: Time to Detect = 6 minutes | Time to Contain = 52 minutes (from detection) | Time to Recover = 2 days, 14 hours (from detection)

Saturday — Initial Compromise & Detection (Overnight)

1:47 AM	PRE-DETECTION A delayed-send phishing email, timed for low-staffing hours, is auto-opened by a mail rule on a shared Accounts Payable mailbox; embedded payload executes and harvests cached credentials. <i>Attacker activity</i>
1:52 AM	DETECTION MSSP EDR tooling flags anomalous mass file-modification behavior and a privilege escalation attempt; MSSP After-Hours SOC Analyst begins triage immediately. <i>MSSP SOC Analyst</i> ✓ Automated detection — no human had to notice first
1:53 AM	DETECTION MSSP confirms high-severity ransomware indicators per the pre-agreed escalation protocol and immediately calls the on-call Technical Lead. <i>MSSP → On-Call Technical Lead</i>
1:58 AM	DETECTION On-call Technical Lead confirms the alert remotely, declares a formal security incident, and calls the on-call Incident Commander. <i>Technical Lead → Incident Commander</i>
2:04 AM	DETECTION Incident Commander activates the IR Team remotely; Core team begins responding within minutes; Extended Team notified for morning follow-up given the hour. <i>Incident Commander</i> ⚠ Extended Team not woken at 2 AM — acceptable triage call here, but created a brief information gap (see Lessons Learned)

Saturday — Containment (Overnight)

2:10 AM	CONTAINMENT MSSP, with remote authorization from the on-call Technical Lead, isolates the affected endpoint and shared file server from the network. <i>MSSP SOC Analyst</i>
2:21 AM	CONTAINMENT On-call Systems Administrator remotely disables the compromised account and two additional accounts showing suspicious activity. <i>Systems Administrator (remote)</i>
2:35 AM	CONTAINMENT Technical Lead recommends segmenting the finance subnet; Incident Commander approves remotely. <i>Technical Lead → Incident Commander</i>
2:50 AM	CONTAINMENT Night-shift Production Floor Supervisor confirms no abnormal behavior on the active line; precautionary network isolation applied to the production subnet pending daylight review. <i>Production Floor Supervisor</i>

9:15 AM	CONTAINMENT Incident Commander briefs the now-awake Extended Team; Finance Lead notifies the Cyber Insurance Carrier, who approves engaging the pre-contracted External IR Firm. <i>Finance Lead → Incident Commander</i> ⚠️ Carrier notification waited for business hours rather than being made overnight (see Lessons Learned)
11:40 AM	CONTAINMENT Legal/Compliance Lead completes evidence preservation and files an FBI IC3 report given the ransom note contents. <i>Legal/Compliance Lead</i>

Saturday–Sunday — Eradication

Sat, 2:30 PM	ERADICATION External IR Firm establishes remote access and begins forensic analysis to confirm ransomware variant and full scope. <i>External IR Firm + Technical Lead</i>
Sun, 8:00 AM	ERADICATION Forensic analysis confirms the variant and scope: 11 affected endpoints plus the shared file server; production systems confirmed clean. <i>External IR Firm + Controls Engineer</i>
Sun, 1:00 PM	ERADICATION Systems Administrator rebuilds all 11 affected endpoints from clean images. <i>Systems Administrator</i>
Sun, 7:30 PM	ERADICATION Security Analyst confirms no remaining indicators of compromise; Technical Lead reports eradication complete. <i>Security Analyst → Technical Lead</i>

Sunday–Monday — Recovery

Sun, 8:00 PM	RECOVERY Systems Administrator restores the shared file server from the most recent verified-clean backup. <i>Systems Administrator</i>
Mon, 5:00 AM	RECOVERY File server validated and rebuilt endpoints redeployed ahead of Monday's day shift. <i>Systems Administrator</i> ✓ Recovery deliberately timed to finish before Monday's shift change
Mon, 6:00 AM	RECOVERY Controls Engineer reconnects the production subnet ahead of the day shift; full production capacity confirmed. <i>Controls Engineer</i>
Mon, 7:00 AM	RECOVERY Communications Lead sends an all-clear update; Customer/Supply Chain Liaison confirms to key accounts that no shipment delays occurred. <i>Communications + Liaison</i>
Mon, 4:00 PM	RECOVERY After an elevated monitoring period with no recurrence, Technical Lead, OT/Production Lead, and Legal/Compliance Lead all sign off; Incident Commander formally closes the incident. <i>Incident Commander</i>

3. Lessons Learned

What Worked Well

The 24/7/365 hybrid MSSP model performed exactly as designed — automated detection in under 6 minutes prevented what could have been a multi-hour, business-hours-dependent delay. The decision discipline (no rushing eradication before containment was confirmed, no recovery before sign-off from three separate roles) held up under simulation, validating the phase-gate structure built into the IR Plan.

Finding 1: Cyber insurance notification was not treated as a 24/7 action

Root Cause: The IR Plan correctly established 24/7 technical escalation, but the path to the Cyber Insurance Carrier was only ever defined as a Finance Lead responsibility, and the Finance Lead was not included in the on-call rotation.

Why It Matters: Many cyber insurance policies have notification requirements measured in hours, not business days. A multi-hour delay is a coverage risk that shouldn't depend on luck.

Policy Update: Add Cyber Insurance Carrier notification to the Incident Commander's immediate on-call checklist rather than routing through the Finance Lead first. Updates IR Plan Section 2 (Roles) and the Containment Procedure.

Finding 2: Extended Team experienced a multi-hour information gap overnight

Root Cause: No defined threshold existed for when an overnight incident becomes serious enough to warrant waking the Extended Team versus waiting for morning.

Why It Matters: This worked out fine because the incident was contained quickly. A larger-scope incident (e.g., confirmed data exposure) could threaten breach notification deadlines that start counting from discovery.

Policy Update: Defined a Severity-Based Escalation Matrix (now IR Plan Section 8): Critical/High severity incidents involving data exposure require immediate Legal/Compliance notification regardless of hour.

Finding 3: No defined after-hours coverage process existed before this exercise

Root Cause: Prior to this tabletop exercise, the IR Plan assumed business-hours detection. The need for 24/7/365 coverage was identified only through simulation, not through a prior structured risk assessment.

Why It Matters: This is the most important finding: tabletop exercises exist specifically to surface untested assumptions before a real incident does.

Policy Update: Formalized a semi-annual recurring tabletop exercise requirement (now IR Plan Section 9), rotating scenario types and time-of-day assumptions, with findings tracked to closure before the next exercise.